

ENTERPRISE SECURITY ASSESSMENT LAB

CLOUD SECURITY ASSESSMENT REPORT

Professional Portfolio Edition - AWS CloudGoat, IAM, S3, EC2 IMDS, ScoutSuite and Azure Cleanup
Evidence

Prepared By	Jagriti Banerjee
Repository	Enterprise-Security-Assessment-Lab
Module	04-cloud-security
Primary Provider	Amazon Web Services
Additional Provider	Microsoft Azure
Assessment Type	Authorized vulnerable cloud lab assessment
Primary Lab	CloudGoat / Cloud security learning environment
Document Purpose	GitHub portfolio report for recruiters and technical reviewers

Ethics and safety statement: This report documents testing performed only inside personal, authorized cloud lab environments. Screenshots have been redacted for cloud account identifiers, secrets, temporary credentials, tokens, ARNs and billing-sensitive information before publication.

Table of Contents

1. Executive Summary
2. Engagement Scope and Environment
3. Cloud Lab Architecture
4. Tools and Technologies Used
5. Assessment Methodology
6. AWS CLI Authentication and Identity Verification
7. IAM Permission Enumeration
8. Pacu Privilege Escalation Review
9. S3 Public Access Testing
10. ScoutSuite AWS Audit
11. EC2 IMDS Credential Exposure
12. CloudGoat Objective and Cleanup
13. Azure Security Attempt and Cleanup
14. Findings Summary
15. MITRE ATT&CK; Mapping
16. Remediation Roadmap
17. Evidence Mapping
18. GitHub Redaction Checklist
19. Conclusion

1. Executive Summary

This Cloud Security Assessment Report documents the cloud portion of the Enterprise Security Assessment Lab. The objective was to demonstrate practical cloud security testing skills across AWS identity, permissions, vulnerable cloud paths, storage exposure checks, metadata credential exposure, automated cloud auditing, and responsible cleanup. The work was completed in an authorized lab environment and is intended for professional GitHub portfolio review.

The primary provider for this module was AWS, using CloudGoat-style vulnerable cloud scenarios and security tooling such as AWS CLI, Pacu and ScoutSuite. Azure activity was also documented at a safe operational level, including Azure CLI authentication, AzureGoat deployment limitations, Terraform cleanup, and resource group deletion verification. This report avoids claiming unsupported GCP work or production cloud testing.

High-Level Outcomes

Area	Outcome	Professional Value
AWS CLI Identity	Authenticated lab profile verified	Shows cloud CLI readiness and safe profile usage
IAM Enumeration	Identity and policies reviewed	Demonstrates least-privilege review capability
Pacu Privilege Escalation	Privilege escalation paths analyzed	Shows IAM attack-path awareness
S3 Public Access Test	Unauthenticated access behaviour tested	Shows public exposure validation method
ScoutSuite Audit	Cloud audit dashboard and finding reviewed	Shows security posture assessment workflow
EC2 IMDS Exposure	Temporary metadata credentials retrieved in lab	Shows impact of overly reachable metadata service
CloudGoat Cleanup	EC2 cleanup and billing checks performed	Shows responsible cloud lab operation
Azure Attempt/Cleanup	Quota-limited AzureGoat work cleaned up	Shows safe cloud-cost control and transparency

Overall Risk Narrative

The most important lesson from the cloud lab is that cloud compromise often depends on chained weaknesses rather than one isolated issue. A low-privileged identity may become dangerous if it can enumerate IAM permissions, discover role assumptions, create resources, pass roles to compute, access metadata credentials, or interact with public storage. The report therefore focuses on identity-first security, least privilege, metadata hardening, public storage prevention, automated audit discipline, and cleanup verification.

2. Engagement Scope and Environment

Category	In Scope
Cloud Provider	AWS as primary provider; Azure as secondary attempted/cleanup provider
Lab Type	Authorized personal vulnerable cloud lab
AWS Services Reviewed	IAM, STS, EC2, S3, EC2 Instance Metadata Service, billing/cost dashboard
Tools	AWS CLI, CloudGoat, Pacu, ScoutSuite, curl, jq, Terraform/Azure CLI for cleanup evidence
Evidence	Screenshots stored in 04-cloud-security/screenshots and used as report evidence
Out of Scope	Production cloud systems, third-party accounts, real customer data, destructive activity, persistent access, GCPGoat

Rules of Engagement

- Use only personal lab accounts and intentionally vulnerable cloud scenarios.
- Do not publish AWS account IDs, ARNs, access keys, secret keys, session tokens, bucket names, subscription IDs, tenant IDs, or billing-sensitive values.
- Destroy lab resources immediately after testing and verify cleanup in both CLI and console where possible.
- Document quota failures and cleanup honestly instead of overclaiming successful exploitation.
- Keep Terraform state, cloud credential files, Pacu sessions and ScoutSuite raw reports out of GitHub unless fully sanitized.

3. Cloud Lab Architecture

The lab architecture follows a typical cloud security learning pattern: a dedicated cloud profile is used to deploy vulnerable resources, enumerate identity and permissions, analyze privilege escalation paths, validate exposure behaviours, and then destroy resources. The assessment is evidence-based and maps each major action to screenshots and sanitized output.

```
Local Kali / Cloud Shell Workstation
|
| AWS CLI profile: cloudgoat
v
AWS Account / CloudGoat Lab
|-- IAM user and policies
|-- EC2 resources and instance profiles
|-- S3 bucket access tests
|-- ScoutSuite HTML audit report
|-- EC2 metadata credential validation
|-- Cleanup and billing verification

Azure Portal / Azure CLI
|-- Azure account authentication
|-- AzureGoat deployment attempt
|-- Resource group cleanup verification
```

4. Tools and Technologies Used

Tool	Purpose	Why It Matters
AWS CLI	Identity verification, IAM enumeration, S3 checks, EC2 cleanup checks	Core cloud operations and evidence collection tool
CloudGoat	Deploy intentionally vulnerable AWS scenarios	Provides safe hands-on cloud attack-path learning
Pacu	AWS exploitation framework and privilege escalation scanner	Highlights risky IAM permission combinations
ScoutSuite	Automated AWS security audit report generation	Produces security posture findings across AWS services
curl	Manual HTTP requests to metadata endpoints	Used to validate IMDS credential exposure behaviour
jq	JSON formatting and output readability	Improves analysis of AWS CLI and metadata responses
Terraform	Infrastructure deployment/cleanup awareness	Relevant to AzureGoat/CloudGoat resource lifecycle
Azure CLI / Cloud Shell	Azure authentication and cleanup verification	Demonstrates multi-cloud operational awareness

5. Assessment Methodology Overview

The methodology used for this cloud module is structured as an identity-first cloud assessment. It begins by confirming authentication and the current principal, then moves through permission enumeration, privilege escalation path

analysis, public exposure testing, metadata credential validation, automated audit review, and cleanup verification.

1. Authenticate to cloud lab profile
2. Verify current identity with STS
3. Enumerate IAM permissions and policies
4. Analyze possible privilege escalation with Pacu
5. Test S3 unauthenticated access behaviour
6. Run ScoutSuite AWS audit and review findings
7. Validate EC2 IMDS credential exposure in lab path
8. Complete CloudGoat objective and destroy resources
9. Verify EC2 cleanup and billing / Free Tier status
10. Document Azure authentication, quota limitation and cleanup

6. AWS CLI Authentication and Identity Verification

The first technical step was to confirm that the dedicated lab AWS CLI profile could authenticate successfully. This prevents accidental testing against the wrong account and establishes the current principal before enumeration or exploitation testing.

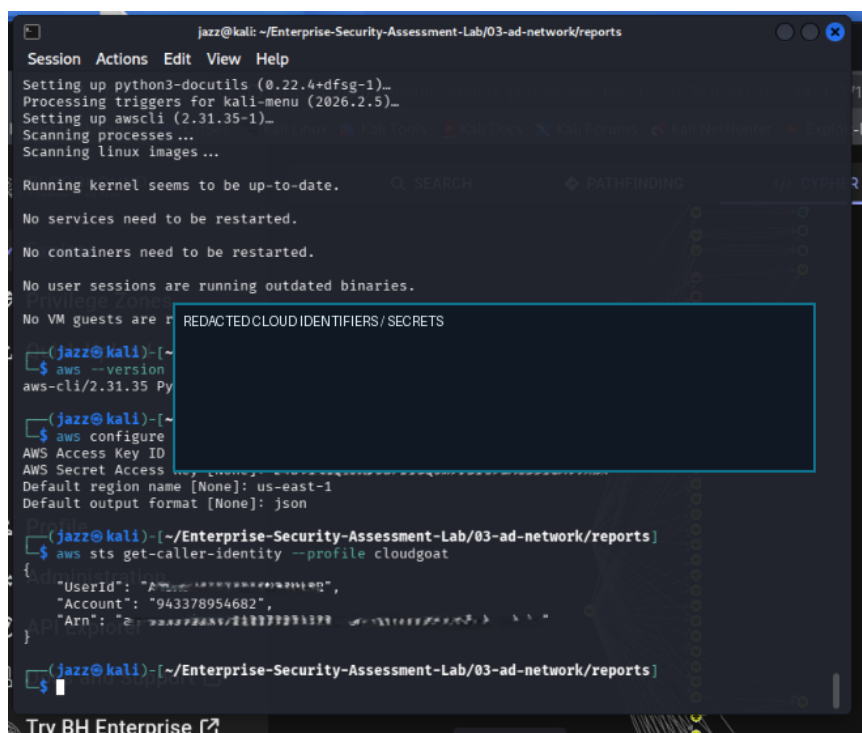
Command Workflow

```
PROFILE=cloudgoat
REGION=us-east-1
aws sts get-caller-identity --profile $PROFILE --region $REGION
```

Sanitized Output Style

```
{
  "UserId": "<REDACTED_USER_ID>",
  "Account": "<REDACTED_ACCOUNT_ID>",
  "Arn": "arn:aws:iam::<REDACTED_ACCOUNT_ID>:user/<REDACTED_LAB_USER>"
}
```

Evidence



```
jazz@kali: ~/Enterprise-Security-Assessment-Lab/03-ad-network/reports
Session Actions Edit View Help
Setting up python3-docutils (0.22.4+dfsg-1)...
Processing triggers for kali-menu (2026.2.5)...
Setting up awscli (2.31.35-1)...
Scanning processes ...
Scanning linux images ...

Running kernel seems to be up-to-date.
No services need to be restarted.
No containers need to be restarted.
No user sessions are running outdated binaries.
No VM guests are running outdated binutils.
REDACTED CLOUD IDENTIFIERS / SECRETS
(jazz@kali)~$ aws --version
aws-cli/2.31.35 Py
(jazz@kali)~$ aws configure
AWS Access Key ID
AWS Secret Access
Default region name [None]: us-east-1
Default output format [None]: json
(jazz@kali)~/Enterprise-Security-Assessment-Lab/03-ad-network/reports$
$ aws sts get-caller-identity --profile cloudgoat
{
  "UserId": "A...",
  "Account": "943378954682",
  "Arn": "arn:aws:iam::943378954682:user/..."
}
```

Figure - AWS CLI authentication using get-caller-identity with account identifiers redacted.

Security Interpretation

Identity verification is a required control step before cloud security testing. It confirms who the current principal is and prevents accidental activity in the wrong account. In cloud assessments, the identity is the starting point for nearly every attack path, including role assumption, policy enumeration, PassRole abuse, and access to data resources.

7. IAM Permissions Enumeration

IAM permission enumeration identifies what the starting identity can do. Cloud privilege escalation frequently depends on combinations of permissions, such as the ability to create access keys, attach policies, pass roles, run instances, assume roles, or modify trust relationships.

Command Workflow

```
aws iam get-user --profile $PROFILE
aws iam list-attached-user-policies --user-name <REDACTED_USER> --profile $PROFILE
aws iam list-user-policies --user-name <REDACTED_USER> --profile $PROFILE
aws iam get-user-policy --user-name <REDACTED_USER> --policy-name <REDACTED_POLICY_NAME>
--profile $PROFILE
```

Risky Permissions Reviewed

Permission Family	Why It Is Sensitive
iam:PassRole	Can allow a user to attach a more privileged role to a service such as EC2 or Lambda
iam:AttachUserPolicy / PutUserPolicy	Can grant additional permissions to the current user
iam:CreateAccessKey	Can create long-lived credentials for users
sts:AssumeRole	Can pivot into another role if trust policy allows it
ec2:RunInstances	Can create compute resources and attach instance profiles
s3:* or broad S3 access	Can expose or modify object storage data

Evidence

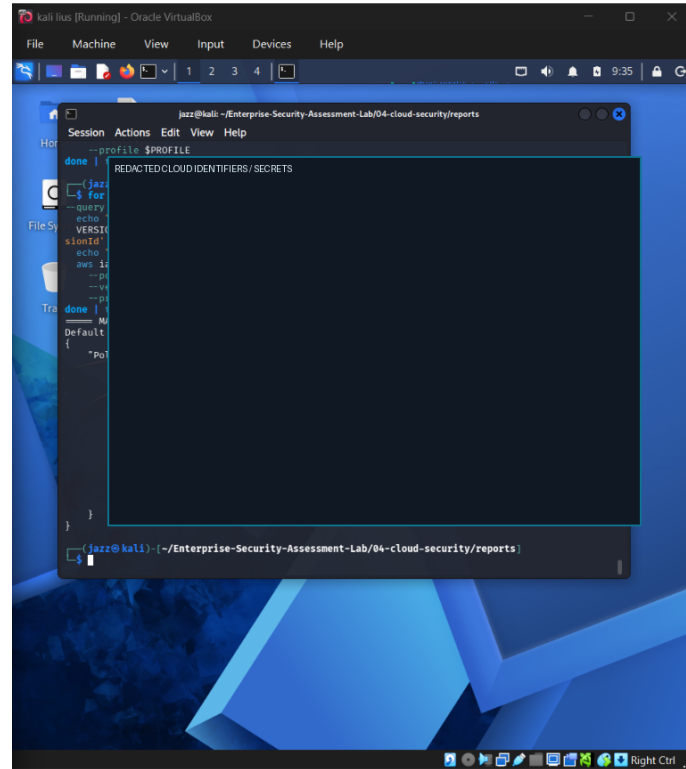


Figure - IAM permission enumeration evidence with identity/policy details redacted.

Remediation

- Apply least privilege to all IAM users, roles and service accounts.
- Avoid wildcard actions and wildcard resources in production policies.
- Restrict iam:PassRole with explicit service and role constraints.
- Use permission boundaries for identities that may create or modify IAM resources.
- Monitor IAM policy changes with CloudTrail, EventBridge and security alerts.

8. Pacu Privilege Escalation Review

Pacu was used to analyze AWS privilege escalation possibilities in the vulnerable lab. This type of review helps identify whether the starting cloud identity can move from limited access to higher privilege through IAM, EC2, role assumption or policy abuse.

Command Workflow

```
pacu
import_keys cloudgoat
set_regions
us-east-1
whoami
run iam_privesc_scan
```

Evidence

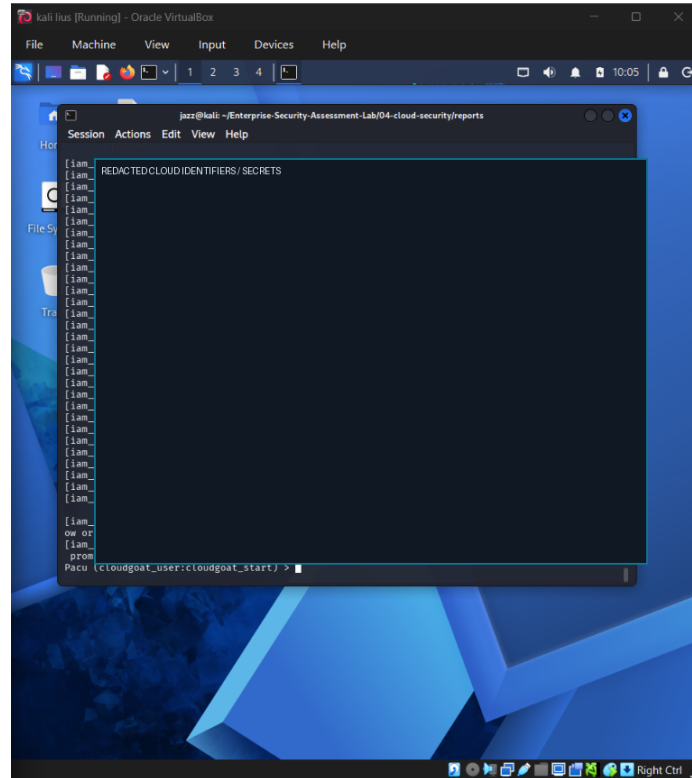


Figure - Pacu privilege escalation scan results with sensitive identifiers redacted.

Security Interpretation

Privilege escalation findings are not only about a single dangerous permission. They are often about combinations: a user can create an instance, pass a powerful role, retrieve credentials from IMDS, or modify a policy. Pacu helps automate the discovery of these chains, but every finding should be manually validated and documented with context.

Remediation

- Continuously review IAM policies for privilege-sensitive actions.
- Restrict role-passing and role-assumption permissions to expected workflows only.
- Use service control policies in multi-account environments.
- Alert on iam:AttachUserPolicy, iam:PutUserPolicy, iam:PassRole and ec2:RunInstances by unexpected principals.

9. S3 Public / Unauthenticated Access Testing

S3 unauthenticated access testing checks whether a bucket can be accessed without AWS credentials. This is important because public buckets are a common source of cloud data exposure involving logs, backups, configuration files, application artifacts or credentials.

Command Workflow

```
aws s3 ls --profile $PROFILE
aws s3 ls s3://<REDACTED_BUCKET_NAME> --no-sign-request
aws s3api get-public-access-block --bucket <REDACTED_BUCKET_NAME> --profile $PROFILE
aws s3api get-bucket-policy-status --bucket <REDACTED_BUCKET_NAME> --profile $PROFILE
```

Evidence

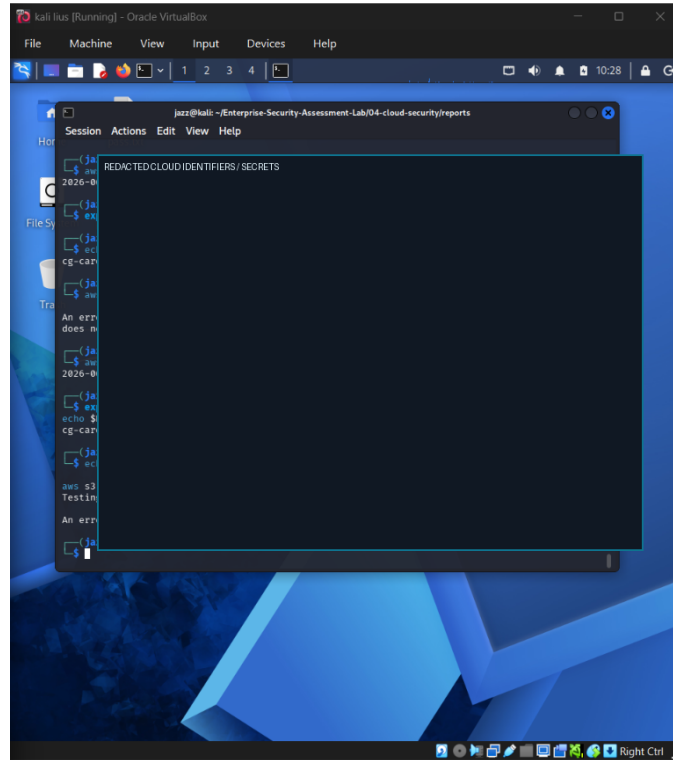


Figure - S3 unauthenticated access behaviour test with bucket identifiers redacted.

Professional Result Wording

If the screenshot shows object listing without credentials, document it as public access confirmed. If it shows AccessDenied, document it as unauthenticated access tested and public listing not confirmed. Do not overclaim beyond the evidence.

Remediation

- Enable S3 Block Public Access at account and bucket level unless public access is explicitly required.
- Review bucket policies for Principal "*" and broad s3:GetObject or s3:ListBucket permissions.
- Disable legacy ACL-based exposure where possible.
- Use AWS Config, Security Hub and IAM Access Analyzer to detect public exposure.

10. ScoutSuite AWS Security Audit

ScoutSuite was used to perform an automated AWS security audit. The generated HTML report provides a dashboard-style view of findings across IAM, EC2, S3 and other AWS services. Automated audit findings should be treated as leads and reviewed manually before being reported as confirmed vulnerabilities.

Command Workflow

```
scout aws --profile $PROFILE --regions $REGION --no-browser --report-dir ./scoutsuite-report  
find ./scoutsuite-report -name "*.html" | head -1
```

Evidence

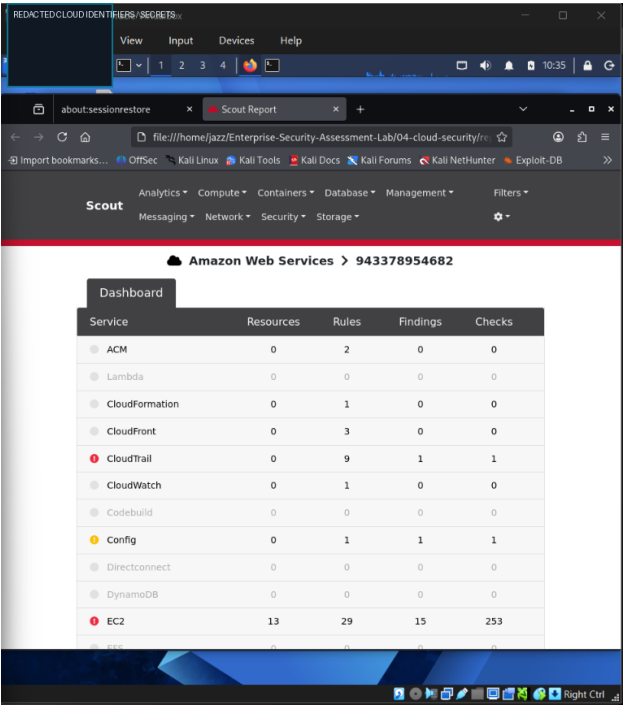


Figure - ScoutSuite HTML report overview dashboard.

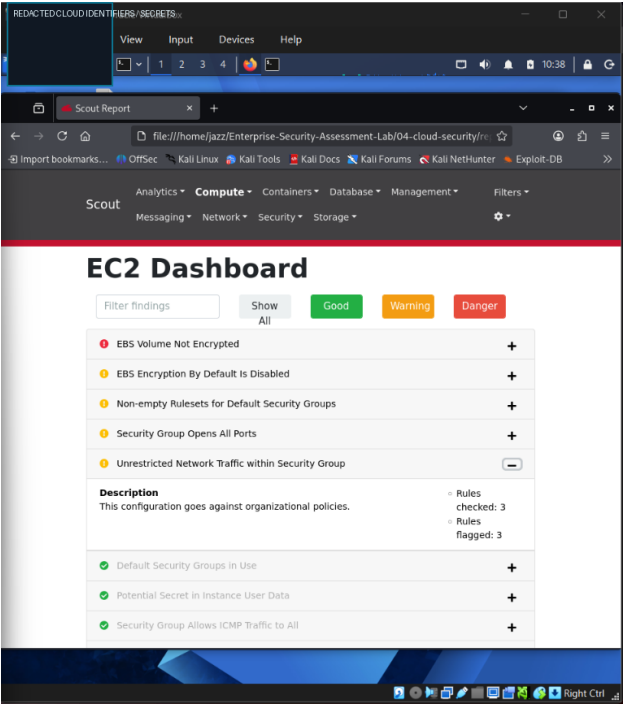


Figure - ScoutSuite specific high-severity finding review.

Security Interpretation

ScoutSuite provides broad cloud posture visibility. In a real environment, findings should be prioritized based on exploitability, exposed assets, privilege level, internet reachability, data sensitivity and whether the finding is already mitigated by compensating controls.

Remediation

- Run cloud audit tooling regularly and compare results over time.
- Prioritize IAM, public exposure, network and logging findings first.

- Review findings manually before reporting them as confirmed issues.
- Use AWS native services such as Security Hub, Config, GuardDuty and CloudTrail to support continuous monitoring.

11. EC2 IMDS Credential Exposure Testing

The EC2 Instance Metadata Service can expose temporary credentials for the instance profile attached to an EC2 instance. In vulnerable scenarios, attackers may reach the metadata endpoint through SSRF, command execution, compromised workloads or insecure network paths. This lab validates the risk in a controlled environment.

Command Workflow

```
curl -s http://169.254.169.254/latest/meta-data/  
curl -s http://169.254.169.254/latest/meta-data/iam/security-credentials/  
curl -s http://169.254.169.254/latest/meta-data/iam/security-credentials/<REDACTED_ROLE_NAME> |  
jq
```

Evidence

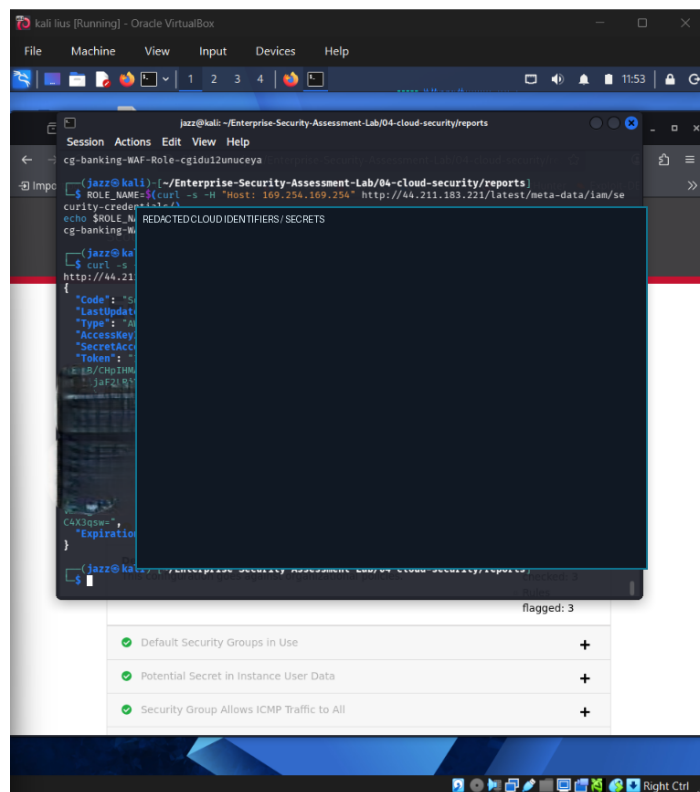


Figure - EC2 metadata credential exposure evidence with temporary credentials fully redacted.

Impact

Metadata credentials are temporary, but they are valid AWS credentials. If the attached instance role is overly privileged, attackers can use the exposed credentials to access cloud resources, enumerate data, interact with S3, assume roles, modify infrastructure, or continue privilege escalation.

Remediation

- Require IMDSv2 on all EC2 instances.
- Apply least privilege to instance profiles and avoid broad IAM permissions.
- Harden applications against SSRF and command execution vulnerabilities.

- Monitor CloudTrail for unexpected use of instance-role credentials from unusual locations.
- Rotate exposed credentials and review all activity if metadata credentials are leaked.

12. CloudGoat Objective and EC2 Cleanup Verification

Responsible cloud testing requires cleanup verification. Vulnerable lab resources can create security exposure and unexpected billing if left running. The report therefore includes evidence of CloudGoat resource destruction and EC2 cleanup verification.

Command Workflow

```
cloudgoat destroy <SCENARIO_NAME>
aws ec2 describe-instances --profile $PROFILE --region $REGION
aws ec2 describe-instances --filters Name=instance-state-name,Values=running --profile $PROFILE
--region $REGION
```

Evidence

```
jazz@kali: ~/Enterprise-Security-Assessment-Lab/04-cloud-security/reports
Session Actions Edit View Help
Destroy "iam_privsec_by_attachment_cgoat" [y/n]: y
No terraform.tfstate file was found in the scenario instance's terraform directory, so "terraform
destroy" will not be run.
Successfully destroyed scenario in on3.13/site
jazz@kali:~/Enterprise-Security-Assessment-Lab/04-cloud-security/reports$ ls -lh
-rw-r--r-- 1 jazz jazz 4096 Nov 13 15:01 rm -f c
jazz@kali:~/Enterprise-Security-Assessment-Lab/04-cloud-security/reports$ aws ec2
--profile
--region
--query
--output
DescribeInstances
+-----+-----+-----+-----+
| i-0151b3958f5679939 | terminated | CloudGoat | super-critical-security-server E
C2 Instance
| i-0151b3958f5679939 | terminated | None
+-----+-----+-----+-----+
jazz@kali:~/Enterprise-Security-Assessment-Lab/04-cloud-security/reports$
```

Figure - CloudGoat EC2 cleanup verification evidence with cloud identifiers redacted.

Operational Risk

Cloud labs frequently create EC2, IAM, S3 and networking resources. If cleanup is incomplete, the account can retain public attack surface, exposed resources, unused credentials and unexpected costs. Cleanup should be treated as a mandatory phase of every cloud lab.

13. AWS Free Tier / Billing Verification

Billing verification confirms that no unexpected charges or active billable resources remain after the lab. This is an important professional habit for cloud security learners because exploitation labs often create compute, network and storage resources that can continue billing after testing ends.

Evidence

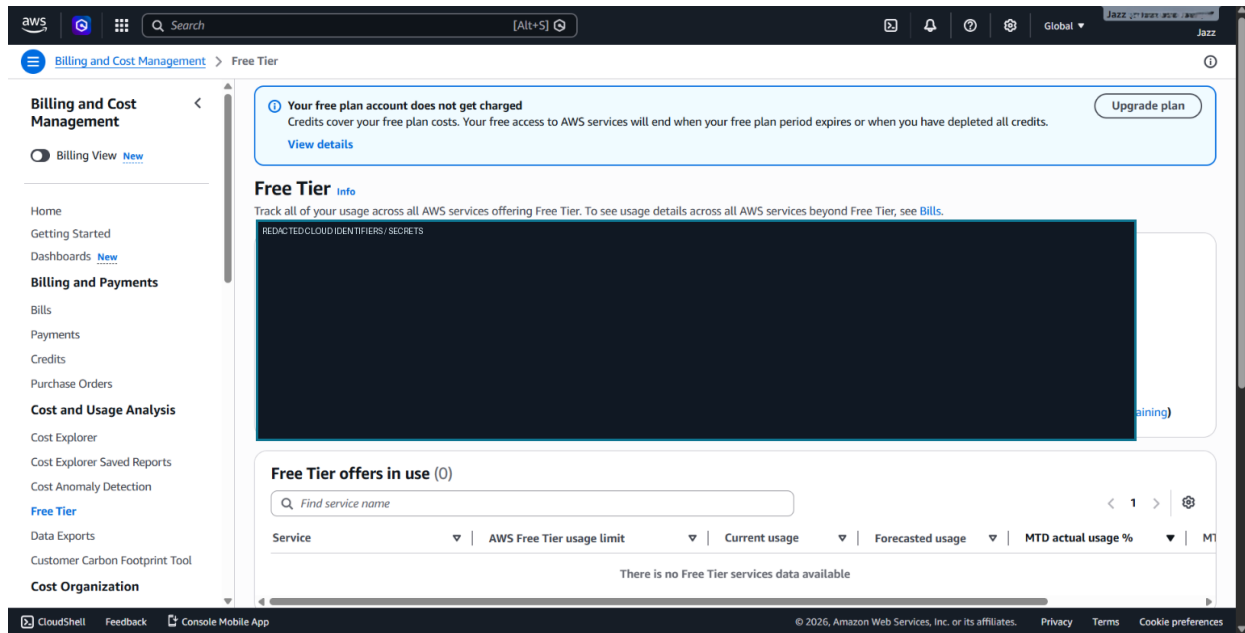


Figure - AWS Free Tier / billing dashboard check after cleanup with sensitive billing/account information redacted.

Recommended Controls

- Create AWS Budgets alerts before running cloud labs.
- Use separate lab accounts for vulnerable scenarios.
- Destroy lab scenarios immediately after use.
- Verify EC2, S3, IAM, CloudFormation and VPC resources after testing.
- Review billing dashboards after every cloud lab session.

14. Azure Security Attempt and Cleanup

Azure work in this project was handled responsibly. Azure CLI / Cloud Shell authentication was completed, AzureGoat deployment was attempted, subscription quota limitations were encountered, and cleanup was verified. This is documented as an attempted and safely cleaned up Azure lab, not as a full Azure compromise.

Evidence

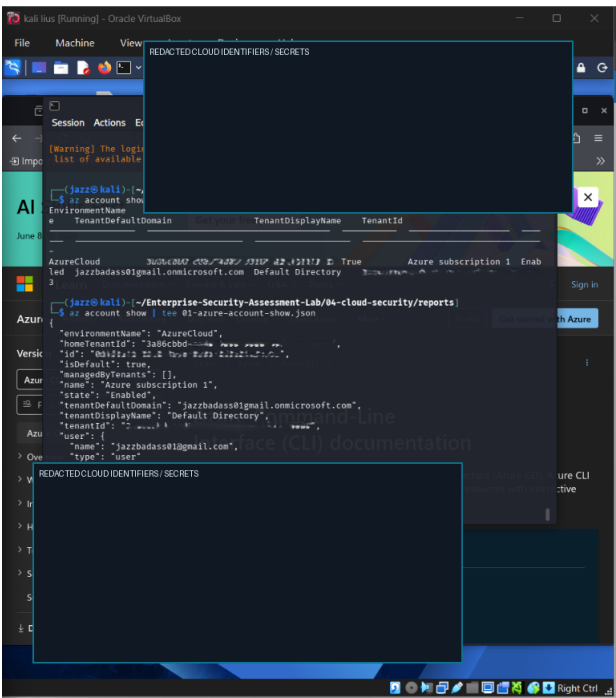


Figure - Azure CLI authentication evidence with subscription and tenant details redacted.

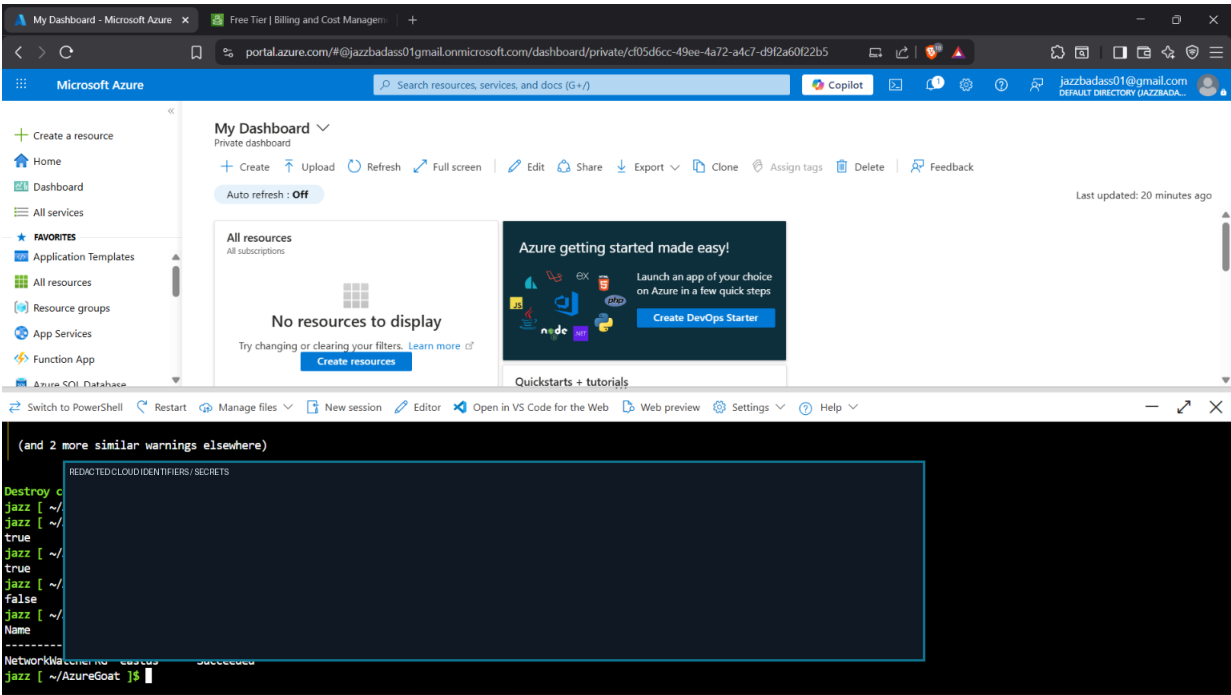


Figure - AzureGoat cleanup confirmation and resource group state check.

Professional Interpretation

This section shows cloud operational maturity: quota errors and cleanup are part of real cloud work. The project should not claim AzureGoat full deployment or exploitation unless supported by evidence. It is accurate to state that AzureGoat was attempted, blocked by quota, and cleaned up responsibly.

15. Findings Summary

#	Finding / Test Case	Service	Severity Style	Evidence	Status
1	AWS CLI identity verified	STS/IAM	Informational	01-aws-cli-authenticated-get-caller-identity.png	Completed
2	IAM permissions enumerated	IAM	Medium	15-iam-permissions-enumeration.png	Completed
3	Pacu privilege escalation paths reviewed	IAM/EC2	High/Critical if exploitable	17-pacu-privesc-scan-results.png	Completed
4	S3 unauthenticated access behaviour tested	S3	Critical if public data exposed	18-s3-public-bucket-unauthenticated-access.png	Tested
5	ScoutSuite cloud audit performed	Multiple AWS services	Medium/High depending finding	19/21-scoutsuite*.png	Completed
6	EC2 IMDS temporary credentials exposed in lab	EC2/IAM	Critical	22-imds-ec2-metadata-credentials-stolen.png	Validated in lab
7	CloudGoat resources cleaned up	EC2/IAM/S3	Operational control	13-cloudgoat-ec2-cleanup-verified.png	Completed
8	Billing / Free Tier check performed	Billing	Operational control	14-aws-free-tier-cleanup-check.png	Completed
9	AzureGoat attempted and cleaned up	Azure	Operational control	23/25-azure*.png	Quota-limited, cleaned up

16. MITRE ATT&CK; Mapping

Activity	Technique	MITRE ID
Cloud account access	Valid Accounts: Cloud Accounts	T1078.004
Cloud/IAM discovery	Cloud Service Dashboard / Permission Groups Discovery	T1538 / T1069
Privilege escalation review	Additional Cloud Roles / Cloud IAM abuse	T1098.003
S3 access testing	Data from Cloud Storage	T1530
EC2 metadata credentials	Unsecured Credentials: Cloud Instance Metadata API	T1552.005
Temporary credential usage risk	Valid Accounts: Cloud Accounts	T1078.004
Resource cleanup verification	Operational hardening / defensive lifecycle control	Defensive control

17. Remediation Roadmap

Priority	Area	Action
P0	Cloud credentials	Never publish access keys, secret keys, session tokens, ARNs, account IDs or Terraform state. Rotate immediately if exposed.
P0	EC2 IMDS	Require IMDSv2 and reduce instance profile permissions.
P1	IAM least privilege	Remove wildcard permissions, restrict PassRole/AssumeRole, review inline policies and apply permission boundaries.
P1	S3 exposure	Enable Block Public Access, review bucket policies and ACLs, monitor public bucket findings.
P1	Monitoring	Enable CloudTrail, GuardDuty, Security Hub and Config where appropriate.
P2	Audit workflow	Run ScoutSuite/Prowler/Security Hub reviews periodically and track remediation.

Priority	Area	Action
P2	Cloud lab hygiene	Use dedicated lab accounts, budgets, resource tagging and post-lab cleanup checks.

18. Evidence Mapping

Evidence Area	Screenshot File
AWS identity verification	01-aws-cli-authenticated-get-caller-identity.png
CloudGoat deployment evidence	02-cloudgoat-scenario-deployed-successfully.png, 03-aws-console-cloudgoat-resources-created.png
Pacu setup and key loading	04-pacu-framework-session-started.png, 05-pacu-cloudgoat-keys-loaded.png
CloudGoat start user / access restrictions	06-cloudgoat-start-user-identity-confirmed.png, 07-cloudgoat-kerrigan-limited-iam-accessdenied.png
EC2 / IAM attack path evidence	08-*.png through 12-*.png
Cleanup and billing	13-cloudgoat-ec2-cleanup-verified.png, 14-aws-free-tier-cleanup-check.png
IAM / Pacu / S3 / ScoutSuite	15-*.png through 21-*.png
IMDS credential exposure	22-imds-ec2-metadata-credentials-stolen.png
Azure authentication and cleanup	23-azure-cli-authenticated.png, 24-azure-cli-authenticated.png, 25-azuregoat-cleanup-confirmed.png

19. GitHub Redaction Checklist

Before uploading cloud screenshots, reports, outputs or raw tool files to GitHub, confirm that the following sensitive values are removed or redacted:

- AWS account IDs, ARNs, user IDs, role names, subscription IDs and tenant IDs if not intentionally public.
- AccessKeyId, SecretAccessKey, SessionToken and temporary EC2 metadata credentials.
- S3 bucket names, object names and policy details if they reveal sensitive naming patterns.
- Terraform state files, .tfvars files, .aws credential folders, Pacu session databases and ScoutSuite raw reports if unredacted.
- Billing account details, emails, subscription identifiers and invoice-related data.
- Public IPs or instance IDs if you want the portfolio to remain generic and reusable.

20. Conclusion

The Cloud Security module demonstrates practical AWS security assessment capability across identity verification, IAM enumeration, privilege escalation analysis, public storage testing, ScoutSuite auditing, EC2 metadata credential exposure, and cleanup/billing verification. The Azure section shows responsible handling of quota limitations and cleanup rather than unsupported overclaiming.

For recruiters and technical reviewers, this report shows not only tool usage but also professional cloud security judgment: validating evidence, redacting secrets, avoiding overclaims, understanding business impact, and cleaning up cloud resources responsibly.

Final publication note: This PDF is a public portfolio version. It is suitable for GitHub after the redacted screenshots and PDF filename are uploaded under **04-cloud-security/reports/**.